# Monthly Intelligence Dispatch

April 2019

**The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID)** is a monthly newsletter by Group-IB, an international company that specialises in preventing cyberattacks and developing information security products. The dispatch aims to provide information about the latest cyberthreats, criminal groups' attacks, leaks, and malware. The document contains news about arrests, legal action against hacking groups, short-term forecasts, and recommendations to help take timely measures to reduce security risks and ensure protection against cyberthreats. Group-IB MTID is intended for internal use only and its distribution is not permitted.

# Key findings

- Unidentified individuals published information about Iran's government-backed hacking groups, Oilrig and MuddyWater, and the company Rana Institute on Telegram.
- 25 variants of the new Exodus mobile spyware were detected on Google Play.
- **The Hong Kong office of Amnesty International**, a human rights organisation, was targeted by state-sponsored hackers believed to be linked to China.
- Cyberattacks, which varied in their success level, were observed in April at Toyota and Hoya Corporation, Japanese companies, and the German chemical giant Bayer.
- **Group-IB's TDS Polygon** system identified attacks on Russian banks, believed to have been carried out by the MoneyTaker group.
- The Silence group shifted their focus from the CIS and its neighbouring countries to international markets. The group's campaigns targeted banks and financial organisations in the UK, India, and South Korea.
- The Cobalt group sent out emails with the subject "last paragraphs" purporting to be from a "banker" named **Harrington Timothy**.
- In addition to their typical malware called Trinity, the FIN6 group is now using Ryuk and LockerGoga ransomware.
- Marcus Hutchins, the British computer security researcher who stopped the **WannaCry** outbreak, pleaded guilty to two charges relating to creating and distributing malware, including the Kronos Trojan.

# Major events: Leaks of Iranian APT groups' operations

Oilrig, MuddyWater and Rana Institute

Unidentified individuals published secret information about Iran's state-sponsored hacking groups on Telegram. First, a user named **Lab Dookhtegan** posted the source code of six tools of the Iranian APT34 group (also known as OilRig and HelixKitten), disclosed IP addresses and domains involved in their operations, and published data on 66 victims, which included **Etihad Airways** and **Emirates National Oil**. **Lab Dookhtegan** also leaked data on the group's previous operations and doxxed Iranian Ministry of Intelligence officers allegedly involved in APT34 operations. There is no doubt that the leak will significantly affect OilRig's future operations.

OilRig is an Iran-linked APT that has been around since at least 2014 and mainly targets organisations in the financial, government, energy, telecommunications, and chemical sectors in the US and the Middle East.

After the OilRig's exposure, another leak emerged in the public eye. The material released on underground forums and Telegram includes information on other Iranian cyber operators, specifically MuddyWater and Rana Institute. This leak was different from the first one. Neither of them included malware source code. Instead, they contained images of a source code of unknown origin, images of command and control server backends, and images listing hacked victims. Hackers known as Green Leakers claimed responsibility for the MuddyWater group leaks. They have several Telegram channels and underground websites, where they advertise and sell data regarding MuddyWater operations. Rana Institute apparently tracked Iranian citizens both within and outside the country. In particular, many of their campaigns focused on hacking airlines (to retrieve passenger manifests) and booking websites (to retrieve reservations and payment card numbers). In addition, the group attacked IT and insurance companies, telecommunications operators, and government agencies worldwide.

# Major events: Espionage, sabotage, leaks

## Exodus

**Security Without Borders** identified 25 variants of a new spyware platform, which they called Exodus by the name of the C&C server. The spyware, which was detected on **Google Play**, was disguised as service applications of various Italian mobile operators. It attracted users by "bonuses" or smartphone performance improvements. While Google Play did not share the exact number of victims, it is estimated to be a few hundred people, all located in Italy. Once a user had their smartphone infected, the owners of the spyware could listen to victims' phone calls, read their messages on social networks, track their location, retrieve a list of installed apps, and take screenshots. Later, researchers at **Lookout** discovered an iOS version of Exodus, equipped with a legitimate Apple developer certificate. The malware was distributed through phishing websites that imitated Italian and Turkmenistani mobile carriers. There have been suggestions that the spyware was developed at the request of law enforcement agencies. The authorities have already started investigating the incident.

## Amnesty International

**Amnesty International Hong Kong** has been attacked by state-sponsored hackers believed to be linked to **China**. It has been reported that after hacking into the infrastructure, the hackers gained access to the names of the organisation's supporters, Hong Kong identity card numbers, and personal contact information, but no financial data was compromised. The initial findings reveal that the attacks were perpetrated using tools and techniques associated with specific advanced persistent threat groups linked to the Chinese government. Amnesty International is a privileged target for state-sponsored hackers because of its activity with other NGOs, opposition, journalists, activists, and civil rights movements worldwide. In August 2018, Amnesty International reported that one of their employees had already been targeted by surveillance malware.

# Major events: Espionage, sabotage, leaks

**Toyota**

The Japanese car manufacturer Toyota reported about a new cyberattack, in which the hackers penetrated the company's systems and gained access to data on 3.1 million owners of Toyota and Lexus cars. The only available information so far is that the customers' financial data was safe, with the leak only affecting Toyota Tokyo Sales Holdings, Tokyo Tokyo Motor, Tokyo Toyopet, Toyota Tokyo Corolla, Nets Toyota Tokyo, Lexus Koishikawa Sales, Jamil Shoji (Lexus Nerima) and Toyota West Tokyo Corolla. This is a second cyberattack on the car industry giant. In February 2019, cybercriminals attacked Toyota Australia, which paralysed the branch office. Experts at FireEye suggested at the time that APT32, a Vietnamese pro-government group, could have been behind the attack and that the hackers were likely trying to reach the company's headquarters in Japan.

**Hoya Corporation**

Another Japanese company Hoya Corporation, an optical systems producer, also suffered an attack. The cryptojackers infected about one hundred computers at the company's plant in Thailand. The employees noticed a heavy load on the servers and stopped the cyberattack. The investigation revealed that the malware reached computers at the corporation's headquarters in Tokyo.

**Bayer**

The German chemical giant Bayer also had problems with hackers, but the corporation said no data had been stolen and their Cyber Defense Center identified, analysed and cleaned up the affected systems. The company said that in early 2018 it discovered an intrusion linked to the Winnti threat actors, a group of Chinese APTs operating under the Chinese state intelligence apparatus. Different groups that form Winnti are tracked as PassCV, APT17, Axiom, LEAD, and GREF. The Winnti group was first discovered in 2013, but has been active since 2007. It has been mainly focusing on the gaming industry, with most of their victims located in Southeast Asia.

# Major events: Espionage, sabotage, leaks

## OilRig

In their new espionage campaigns, the Iran-linked group OilRig is now using new malware called **Karkoff** along with **DNSpionage**, reports **Cisco Talos** threat research team. The hackers are distributing the malware via compromised websites or phishing emails. DNSpionage is a custom RAT that uses HTTP and DNS communication to connect to the C&C server. The new malware, which was discovered in April, is called Karkoff and has been used for reconnaissance purposes. It collects system information related to the workstation environment, the domain, and a list of running processes on the victim's machine. Palo Alto Networks earlier reported that OilRig had long used DNS tunneling in their cyber-espionage campaigns. In particular, many malicious programs that the group has used in their attacks for many years, employ DNS tunneling to protect the communication between infected hosts and the C&C server. DNS tunneling is one of the group's preferred communication methods.

## Facebook

**Cisco Talos** experts found 74 cybercrime-related Facebook groups, with a total of **385,000** participants: Spam Professional, Spammer & Hacker Professional, Buy Cvv On THIS SHOP PAYMENT BY BTC, Facebook hack (Phishing). The contents of these groups are similar to services offered on hacker forums and underground marketplaces, such as selling and purchasing account credentials, phishing tools, bank card information, forged documents, and spamming services, offering assistance in moving large amounts of cash, and selling shell accounts in various organisations (including government). After Cisco Talos contacted Facebook, most of the groups were taken down.

# Major events: Targeted attacks on banks

| | |
|---|---|
| MoneyTaker | **Group-IB's TDS Polygon** system detected attacks on Russian banks. Judging by the infrastructure and instruments used, it is highly likely that the MoneyTaker group is behind the attacks. The attacks employ Metasploit framework's Meterpreter stagers, whose logic is similar to that of the loaders MoneyTaker used in 2016. The attack started in April 2018 at the latest. We reported earlier that on 10 December 2018, a malicious link was identified, which had likely been sent by MoneyTaker from the mail server mail.alfacapital.ru. The email thanked clients for choosing Alfa-Capital, a management company, and falsely claimed that investment fund shares had been successfully issued. The attachment contained a "notification" about changes made in the shareholder register. |
| Cobalt | On 16 April 2019, the Cobalt group sent out emails with the subject "last paragraphs" purporting to be from **Harrington Timothy**. Search engine results show several bankers by the name of Harrington Timothy. There were several emails, similar to the group's previous campaign, which was disguised as emails from individuals well known in the financial sector. Cobalt remained the most aggressive and active threat actor throughout 2018. According to Europol, as at the beginning of 2018, the group had stolen about 1 billion euros from 100 banks in 40 countries. Group-IB forensics specialists were among the first to study Cobalt's attacks on Russian and international banks. The group's phishing emails reached as far as banks in Australia and Japan. Despite the arrest of one of Cobalt's leaders in spring 2018 in the Spanish city of Alicante, attacks on financial organisations continue. |

# Major events: Ransomware

| | |
|---|---|
| FIN6 | The FIN6 group is now using Ryuk and LockerGoga ransomware in addition to their typical malware called Trinity, **FireEye** experts reported. The group was first discovered by FireEye and iSight Partner in 2016. FIN6 specialises in large-scale theft of financial information, such as bank card data obtained in attacks on the retail and hospitality sectors. For a long time, FIN6's main tool was a program called Trinity. However, since July 2018 the hackers have used Ryuk and LockerGoga ransomware. It should be noted that LockerGoga was used in attacks on industrial companies, such as **Norsk Hydro, Hexion and Momentive,** while Ryuk attacked **Wall Street Journal, New York Times, and Los Angeles Times** before the New Year holidays. In their reports, the experts conclude that Ryuk creators are linked to the operators of TrickBot and Emotet malware, whose infrastructure they in effect rent. |
| Silence | The Silence group shifted their focus from the CIS and its neighbouring countries to international markets. According to **Group-IB's Threat Intelligence**, Silence's latest campaigns targeted banks and financial organisations in the **UK**, **India**, and **South Korea**. The cybercriminals have a particular interest in Asia. Group-IB knows about at least one successful attack in Asia. Silence is a small, but very active group of Russian-speaking hackers. It is one of the most dangerous threats to international banks and financial organisations. Group-IB first discovered Silence's activities in 2016, and in September 2018 Group-IB researchers published the first report called **Silence: Moving into the darkside**, which describes the hackers' tools, techniques, and schemes. |

## Arrests and sentences

### Zain Qaiser

The Kingston Crown Court (UK) sentenced Zain Qaiser, a 24-year-old unemployed student, to six years and five months in prison on charges of sextortion and blackmail of pornography site users. Qaiser and his accomplices put up banners on pornography websites. Visitors who clicked on them were redirected to the fraudsters' resource. As a result, malicious programs were downloaded to the victims' computers and a message purporting to be from a law enforcement agency was shown. To unfreeze their victims' screens the fraudsters demanded a payment between $300-$1000. Their actions affected millions of users in 20 countries, with Qaiser collecting at least £700,000. The UK's National Crime Agency discovered several cryptocurrency accounts, where he kept about £100,000. The FBI and the US Secret Service made arrests in relation to this campaign. Experts believe that the criminal worked with **Lurk**, a hacking group that created the Lurk banking Trojan and the Angler exploit kit, which Qaiser also used. The police say Qaiser started engaging in criminal activities in September 2012, almost simultaneously with the appearance of Reveton ransomware. Despite his first arrest in 2014, the hacker was finally stopped only four years later.

### Marcus Hutchins

The person who stopped **WannaCry** admitted he had created malicious programs. Marcus Hutchins, a British security researcher also known as MalwareTech, pleaded guilty to two charges relating to creating and distributing malware including the **Kronos** Trojan. Hutchins was arrested in the summer of 2017. Group-IB observed Kronos as early as 2014 and 2015 and warned its Threat Intelligence subscribers about the start of the Trojan's sale on hacker forums and attacks on bank customers.

# Arrests and sentences

## Business Email Compromise

A US court indicted a group of fraudsters who had used a **business email compromise scheme (BEC)** to steal about **$4.2 million** from companies and individuals. Between 2016-17, **Nkeng Amin** and his five accomplices contacted their victims posing as their business partners and told them that their account numbers for money transfers had been changed. As a result, the fraudsters managed to receive $4.2 million. They did try, however, to obtain as much as $11 million. The organiser of the scheme was sentenced to 87 months in prison, followed by three years of supervised release. He was also ordered to pay more than $1 million in restitution.

## Orcus RAT

The Canadian police raided the residence of **John Rezvesz** also known as Armada, the developer of the Orcus RAT. The information was published by the journalist Brian Krebs and later confirmed by Rezvesz. During the raid, the police seized numerous hard drives with data on the business and practices of Orcus Technologies. The data included user information, such as user names, real names, and financial transactions. According to Rezvesz, Canadian law enforcement agencies are taking part in an international investigation into remote access Trojans together with the US, Germany, Australia and likely other countries. Orcus Technologies has been selling its remote administration tool called Orcus since 2015. Orcus is quite popular among cybercriminals, who have successfully used it for a long time.

# Forecasts and warnings

- After a series of leaks and dumps, the government-backed hacking groups Oilrig and MuddyWater and their contractor Rana Institute are likely to face a post-mortem and will have to make some serious changes in their tools, cover the tracks, and find a potential mole in their ranks. They may stop their attacks for a period of time, but it is likely that there will be imitators of the Iranian hackers.
- Having gained experience attacking Russian banks, the Silence group started successfully applying their skills in their attacks on international companies, preparing infrastructure and testing new tools. The attack on an Indian bank is only the beginning of the Silence's global expansion.
- Anubis, an Android banking Trojan, will be the biggest mobile malware threat. There will also be attacks involving the Android Trojans Red Alert and the new CometBot. Troldesh, one of the most popular ransomware families, will be distributed not only disguised as coming from banks, but also masqueraded as banks' contractors and other companies from various industries, such as retail, wholesale, oil and gas, and construction.
- Meanwhile, Backswap, Trickbot, Gootkit and IcedID will be the most dangerous Windows banking Trojans in Europe, the US and Canada.
- Gozi and Ramnit will remain the most dangerous banking Trojans in Japan.
- The Danabot banking Trojan will extend its geography and apart from Poland will be used in attacks on other European countries.

If you wish to receive more detailed information about a specific incident, threat or criminal group:

Please contact us.

We can conduct investigations to give you the maximum intelligence on the threats targeting your organization.

+1 917 809 47 41
+7 495 984 33 64
intelligence@group-ib.com